Evaluating the Security Posture of Default IaaS Configurations in Azure vs Google Cloud

Akshaykumar Kathirvelu — Cloud Security Assessment Lead (IAM, Network Security & Recommendations)

Abstract

This project aims to evaluate the security posture of default Infrastructure-as-a-Service (IaaS) configurations in Microsoft Azure and Google Cloud Platform (GCP). As organizations increasingly migrate to cloud platforms, many rely on default security settings without fully understanding the risks involved. We compare both platforms across key security dimensions including Identity and Access Management (IAM), storage security, infrastructure configurations, and logging/monitoring. Our goal is to identify vulnerabilities inherent in default settings, provide actionable recommendations, and guide organizations toward more secure cloud practices.

Introduction

Cloud adoption has grown significantly, increasing the need for robust security measures to protect sensitive assets. Microsoft Azure and Google Cloud Platform (GCP) offer strong encryption algorithms, identity management, and threat detection, yet their default IaaS configurations may still pose risks, including permissive access controls and weak encryption policies. This report evaluates the security posture of Azure and GCP's default configurations.

Objectives:

- Assess **infrastructure configurations** for potential vulnerabilities.
- Evaluate **storage security** policies and access controls.
- Compare **logging and monitoring** capabilities.
- Conduct **risk analysis** and provide actionable recommendations.

Methodology

To conduct a comparative security analysis of default configurations in Google Cloud Platform (GCP) and Microsoft Azure, we deployed a controlled test environment in both platforms using their default Infrastructure-as-a-Service (IaaS) settings. Our methodology included the following key steps:

- Cloud Resource Deployment: We provisioned cloud storage buckets and virtual machines on both platforms using default settings. The provisioning process was documented, and any differences—particularly those that could introduce security risks—were identified and analyzed.
- Configuration Assessment: We evaluated the default configurations of virtual machines and storage resources from a security perspective. This included examining aspects such as firewall rules, access control, encryption settings, and public exposure.
- Security Tooling and Documentation Review: We explored and compared the default logging and monitoring tools provided by each platform, including Microsoft Defender for Cloud and Google Security Command Center. Official documentation was reviewed to understand the scope and capabilities of each toolset.
- Comparative Analysis: All findings were systematically compared to assess each platform's approach to default security across infrastructure, storage, monitoring, and overall risk exposure.

Enhanced Security Evaluation Summary:

This extended methodology supplements our core evaluation by incorporating deeper comparative security testing across Microsoft Azure and Google Cloud Platform (GCP). For this stage, we provisioned VMs and storage instances using default configurations and examined them for inherent risks. Key evaluation criteria included IAM policies, public exposure, encryption defaults, logging status, and available threat detection tools. Each platform's support for industry-standard frameworks (like CIS Benchmarks and NIST guidelines) was considered to assess readiness against enterprise security standards.

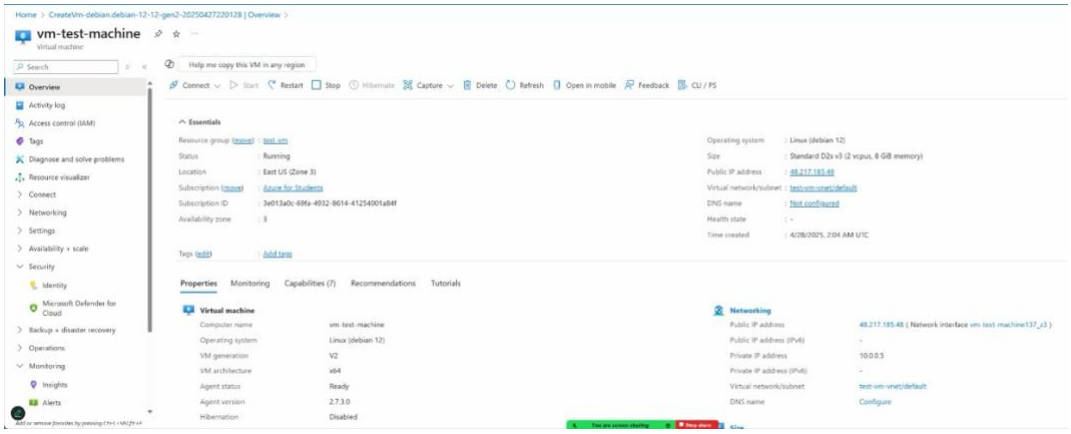
Analysis:

Our extended analysis revealed that while both Azure and GCP offer robust foundational security by default, they differ significantly in granularity of control and visibility features. Google Cloud Platform (GCP) stands out with object-level IAM controls, automatic encryption, and Access Transparency - offering fine-grained permissioning and auditability. On the other hand, Microsoft Azure provides deep integration with Azure Active Directory (AD) and supports layered encryption, including double encryption through Customer-Managed Keys layered over platform-managed keys. However, both platforms present security concerns in their default states: GCP's default service accounts often have broad project-level permissions, increasing the risk of privilege escalation, whereas Azure's default configurations typically have network flow logging disabled, potentially limiting visibility into traffic patterns and lateral movement detection.

1. Virtual Machine Environments

Creating and managing virtual machines (VMs) is central to IaaS usage. Both Microsoft Azure and Google Cloud Platform (GCP) offer flexible deployment and configuration options with built-in security features. However, their default configurations differ in visibility, network isolation, and access management.

- **Azure Virtual Machines:** Azure VMs are provisioned via the Azure Portal, with configurations for OS image, VM size (e.g., B1s), authentication (SSH key or password), and network settings. While Azure offers built-in tools like Defender for Cloud and monitoring options, some security features—such as Network Security Group (NSG) logging and diagnostics—are disabled by default and require manual activation. Azure integrates tightly with Azure AD for identity-based access, and NSGs provide network isolation, though visibility gaps may arise without flow log activation.



- GCP Compute Engine: GCP VMs are created through the Google Cloud Console with customizable specs (e2-micro free tier is default). GCP supports browser-based SSH access and supports Shielded VMs to protect against rootkits and firmware tampering. IAM policies can be applied at the project or instance level. Like Azure, GCP's firewall rules and flow logs must be manually enabled for full visibility. Default service accounts are granted broad permissions, which may introduce privilege escalation risks.

Both Azure and GCP offer flexible VM creation workflows, but they require additional tuning to ensure secure, least-privilege deployments.

Key considerations include:

- **Access Control & Identity Risks:**
  - **Azure:** VM access via Azure AD and RBAC; however, default NSGs and VM monitoring are not fully enabled, potentially exposing gaps.
  - **GCP:** Service accounts assigned to VMs may have project-wide permissions by default, increasing risk if not scoped down.
- Network Segmentation & Visibility:
  - **Azure:** NSGs are used to isolate traffic, but flow logs must be manually activated.
  - **GCP:** VPC Firewall Rules are flexible, yet logging is also disabled by default, reducing immediate network transparency.

2. Infrastructure Configuration (IAM & Network Controls)

Identity and access management (IAM) and network segmentation form the foundation of a secure infrastructure. Azure and GCP both provide comprehensive identity platforms, but default settings may introduce unintended exposure.

- **Azure IAM & Network Controls:** Azure uses Azure AD in conjunction with Role-Based Access Control (RBAC), allowing role assignments at different scopes (subscription, resource group, VM). Managed Identities allow resources to authenticate without storing secrets. Network segmentation is

handled via NSGs, but network logging is not enabled by default, potentially limiting visibility into traffic.

- **GCP IAM & Network Controls:** GCP's IAM supports role bindings at multiple resource levels—from organization down to individual objects—enabling a highly granular least-privilege approach. Network isolation is enforced using VPC firewall rules but logging and audit tracking are off by default. GCP also supports Workload Identity Federation for external identity integration without long-term key storage.

Default configurations in both platforms require customization to ensure proper access boundaries and audit visibility.

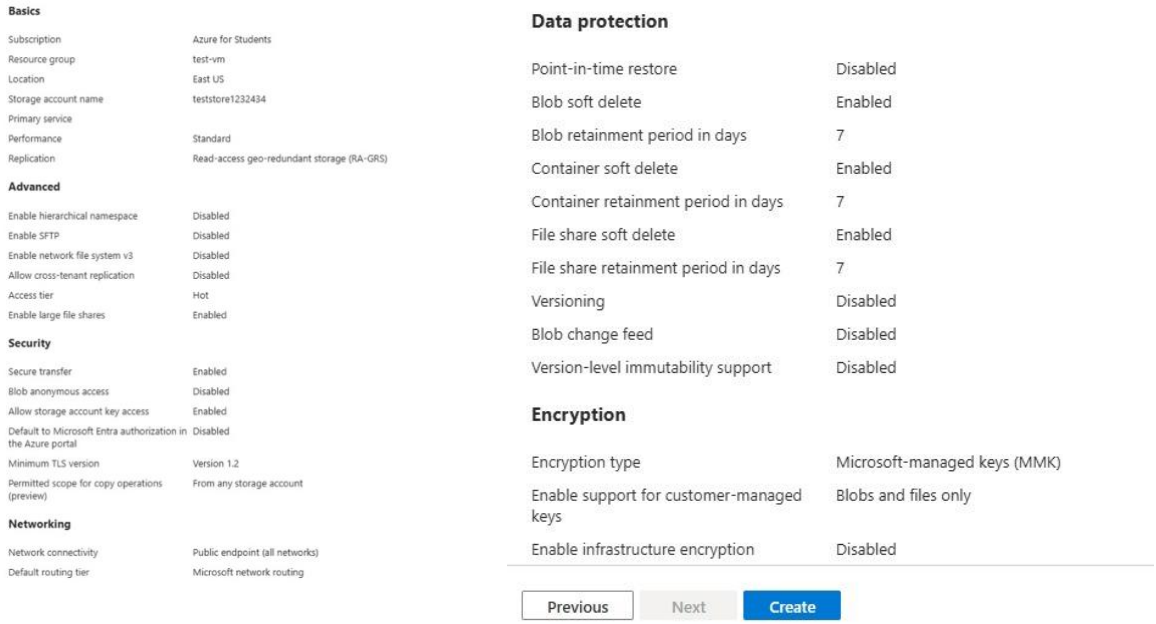
Key considerations include:

- **Privilege Escalation Risks:**
  - **Azure:** Over-permissioned default identities can grant broader access than necessary.
  - **GCP:** Default service accounts are assigned Editor or similar roles, increasing the attack surface.
- **Access Granularity:**
  - **Azure:** IAM granularity is available at the container or storage account level.
  - **GCP:** Supports object-level IAM and organization-wide policy enforcement.

3. Storage Security

Securing data at rest and enforcing proper access control are critical components of any cloud storage strategy. Both Azure and GCP offer strong baseline protections, but they differ in how granular their access controls are, as well as how they manage keys and encryption.

- **Azure** uses Role-Based Access Control (RBAC) to manage permissions at the storage account and container levels. For more granular, object-level access, Shared Access Signatures (SAS) are used, allowing time-limited and permission-specific access. All data is encrypted at rest with AES-256 by default, and HTTPS is required for data in transit. However, one important security consideration is that public access on storage accounts is enabled by default and should be disabled during setup. Azure's key management is handled through Azure Key Vault, offering options for platform-managed, customer-managed, and customer-supplied keys.



Basics

Subscription	Azure for Students
Resource group	test-vm
Location	East US
Storage account name	teststore1232434
Primary service	
Performance	Standard
Replication	Read-access geo-redundant storage (RA-GRS)

Advanced

Enable hierarchical namespace	Disabled
Enable SFTP	Disabled
Enable network file system v3	Disabled
Allow cross-tenant replication	Disabled
Access tier	Hot
Enable large file shares	Enabled

Security

Secure transfer	Enabled
Blob anonymous access	Disabled
Allow storage account key access	Enabled
Default to Microsoft Entra authorization in the Azure portal	Disabled
Minimum TLS version	Version 1.2
Permitted scope for copy operations (preview)	From any storage account

Networking

Network connectivity	Public endpoint (all networks)
Default routing tier	Microsoft network routing

Data protection

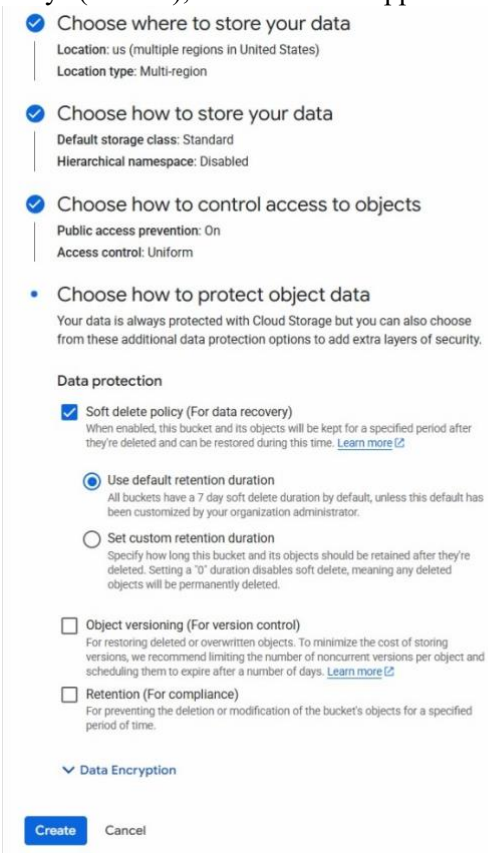
Point-in-time restore	Disabled
Blob soft delete	Enabled
Blob retainment period in days	7
Container soft delete	Enabled
Container retainment period in days	7
File share soft delete	Enabled
File share retainment period in days	7
Versioning	Disabled
Blob change feed	Disabled
Version-level immutability support	Disabled

Encryption

Encryption type	Microsoft-managed keys (MMK)
Enable support for customer-managed keys	Blobs and files only
Enable infrastructure encryption	Disabled

Previous Next Create

- **GCP Storage Security:** GCP provides more fine-grained access control, allowing Identity and Access Management (IAM) policies to be applied directly at the individual object level. Temporary access is managed through Signed URLs. Like Azure, GCP encrypts all stored data with AES-256 by default and protects data in transit using TLS 1.2 or higher. Notably, GCP disables public access by default, offering a slightly stronger out-of-the-box posture. Key management in GCP is handled through Cloud KMS and Cloud HSM, allowing customers to use Google-managed keys, Customer-Managed Encryption Keys (CMEK), or Customer-Supplied Encryption Keys (CSEK).



Key considerations include:

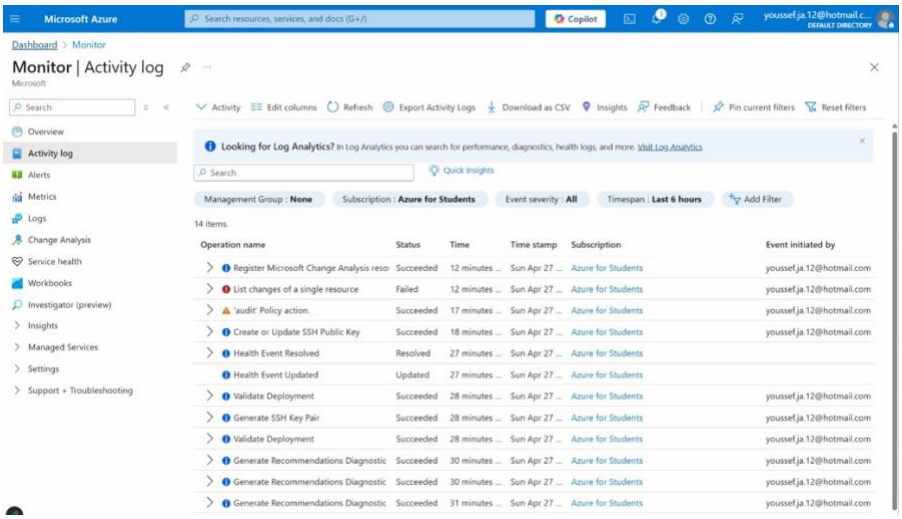
- **Access Control Granularity:**
  - **Azure**: RBAC applies at broader scopes; object-level access requires SAS tokens.
  - **GCP**: Full IAM control down to the object level; no need for separate token systems for fine-grained access.
- **Encryption and Key Management:**
  - **Azure:** Data is encrypted at rest by default (AES 256 encryption); Key Vault provides centralized key management with multiple models (PMK, CMK, CSK).
  - **GCP:** Also encrypts data by default (AES 256 encryption); Cloud KMS offers flexible management of customer-controlled keys (CMEK, CSEK).
- **Authentication & Access Models:**
  - **Azure**: Integrates deeply with Azure AD and supports Managed Identities.
  - **GCP**: Uses service accounts, JWTs, and Workload Identity Federation to eliminate the need for stored secrets.

Overall, both platforms offer strong protections, but GCP provides more granular object-level control and strengthens security by disabling public access by default, whereas Azure requires explicit configuration to achieve the same level of protection.

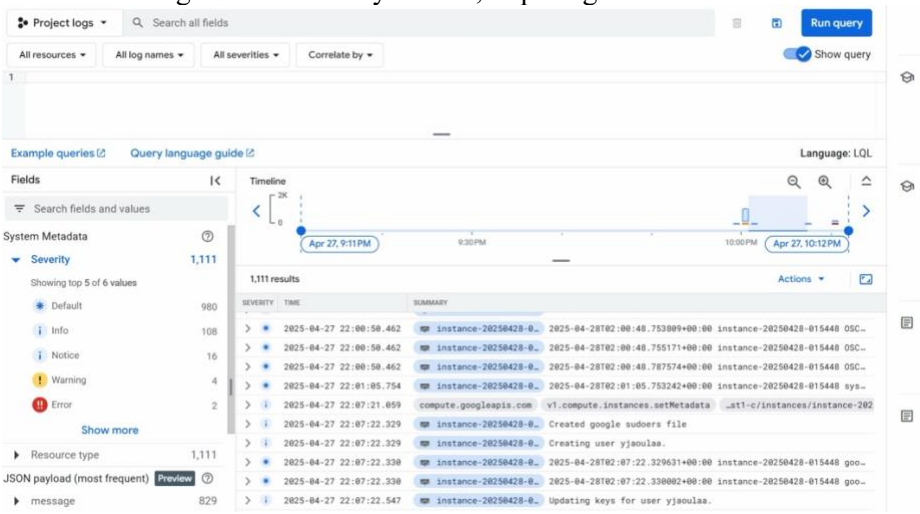
4. Logging & Monitoring:

Effective logging and monitoring are critical components of a secure cloud environment. Both Microsoft Azure and Google Cloud Platform (GCP) provide robust toolsets for visibility and threat detection, but they differ in default configurations, integration depth, and retention capabilities.

Azure Logging & Monitoring: Azure provides a comprehensive suite including Azure Monitor, Activity Logs, Diagnostic Logs, Microsoft Defender for Cloud, and Microsoft Sentinel. These tools collectively offer extensive monitoring of applications, infrastructure, and network resources. However, some capabilities—such as NSG (Network Security Group) Flow Logs and Firewall Logs—must be manually enabled, which introduces potential visibility gaps in default configurations. Although Azure offers free 30-day retention (90 days for some tables), extending this retention requires additional configuration and storage costs.

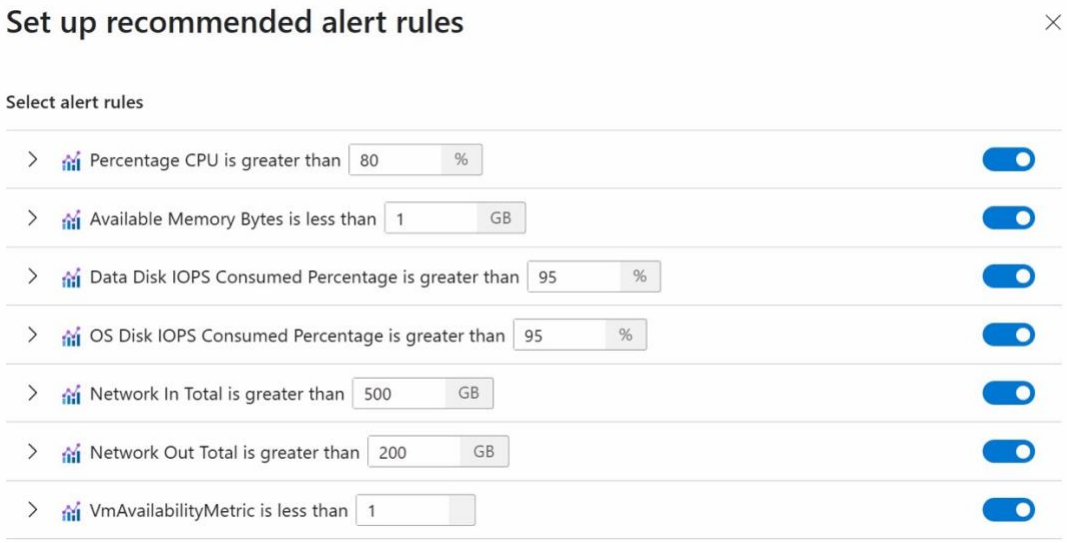


GCP Logging & Monitoring: GCP's ecosystem includes Cloud Monitoring, Cloud Logging, Cloud Audit Logs, and Security Command Center (SCC). These tools provide centralized visibility with automatic integration across services. GCP offers free log storage for up to 365 days if logs are moved to Cloud Storage, giving it a cost-effective edge in long-term retention. However, VPC Flow Logs, Firewall Rule Logs, and API data access logs are disabled by default, requiring manual intervention.



Both Azure and GCP present security risks in their default logging and monitoring configurations, especially when it comes to network visibility and threat detection. Key considerations include:

- **Network Visibility Gaps:**
  - **Azure**: NSG Flow Logs and firewall logging are disabled by default, which may delay detection of unauthorized access or lateral movement.
  - **GCP**: VPC Flow Logs, Firewall Rules Logging, and Data Access Audit Logs are also disabled by default, requiring manual activation to ensure visibility into key activities.
- **Alerting Limitations:**
  - Both platforms offer alerting features, but default thresholds are often too broad.
  - This can lead to missed threats or an overload of false positives, reducing the effectiveness of real-time monitoring.



- **Log Retention and Compliance Risks:**
  - **Azure:** Offers up to 90 days of log retention for certain services.
  - **GCP**: Provides 30 days by default, but allows free long-term storage in Cloud Storage with manual setup.
  - Inadequate retention can result in compliance issues (e.g., PCI-DSS, HIPAA) or insufficient forensic data after an incident.
- **SIEM Integration Differences:**
  - **Azure:** Includes Microsoft Sentinel, a native SIEM with deep integration into its ecosystem.
  - **GCP:** Relies on Chronicle (Google's cloud-native SIEM) for advanced threat detection, which may require additional configuration compared to Azure's natively integrated Microsoft Sentinel.

Recommendations

Below are some key recommendations to follow when provisioning and managing infrastructure in the cloud:

- Implement Principle of Least Privilege
  - Customize IAM roles and permissions to minimize privilege escalation risks.
  - Regularly review and limit IAM roles and policies to enforce least privilege access.
- Enhance Visibility and Threat Detection
  - Enable critical logging features, including network flow logs, firewall logs, and API access logs.

  - Utilize integrated or external SIEM tools (e.g., Microsoft Sentinel, Chronicle, GuardDuty) for continuous monitoring.
  - Customize SIEM rules and alert thresholds to align with the organization's threat model and operational priorities.
- Secure Data with Strong Encryption Practices
  - Activate Customer-Managed Encryption Keys (CMKs) to maintain control over key lifecycle.
  - Enforce automated key rotation policies to meet compliance and security requirements.
- Harden Infrastructure and Network Configuration
  - Customize infrastructure security settings and apply network segmentation to reduce lateral movement.
  - Use Infrastructure as Code (IaC) tools (e.g., Terraform, Bicep) to deploy consistent and secure environments rather than relying on manual console configurations.
- Maintain Compliance and Apply Best Practices
  - Apply established security baselines (e.g., CIS Benchmarks) for virtual machines, storage, and networking.
  - Conduct regular compliance checks against relevant regulatory standards such as HIPAA, GDPR, and FedRAMP.

Conclusion

This study reinforces the critical realization that default configurations in cloud platforms like Azure and Google Cloud are merely foundational and not sufficient for enterprise-grade security. While both platforms offer robust toolsets—including identity and access management, encryption, and monitoring—the default states often leave critical gaps in areas like key control, network visibility, and privilege management.

Through hands-on evaluation and documentation review, we identified significant security variances between Azure and GCP in how they approach access control, encryption enforcement, key storage, and logging. Azure's deep integration with Active Directory and layered encryption provides advantages in hybrid enterprise settings, while GCP's object-level IAM and default transparency features offer superior control and auditability for modern workloads.

Ultimately, organizations must move beyond relying on "secure by default" assumptions. Custom IAM roles, encryption key policies, and proactive logging strategies are essential to minimizing risk and achieving compliance. By applying tailored security enhancements and aligning configurations with regulatory and operational needs, cloud adopters can significantly reduce their threat surface and build a resilient cloud infrastructure that supports innovation without compromising on security.

References

1. Google Cloud. (2024). *Cloud Monitoring overview*. Retrieved from https://cloud.google.com/monitoring
2. Microsoft. (2024). *Azure Monitor documentation*. Retrieved from https://learn.microsoft.com/en-us/azure/azure-monitor/
3. Microsoft. (2024). *Microsoft Defender for Cloud*. Retrieved from https://learn.microsoft.com/en-us/azure/defender-for-cloud/
4. Google Cloud. (2024). *Cloud Logging overview*. Retrieved from https://cloud.google.com/logging
5. Default encryption at rest. (n.d.). Google Cloud. https://cloud.google.com/docs/security/encryption/default-encryption
6. *Cloud Logging documentation | Google Cloud*. (n.d.). Google Cloud. https://cloud.google.com/logging/docs
7. Microsoft. (n.d.). *Azure encryption overview*. Microsoft Learn. https://learn.microsoft.com/en-us/azure/security/fundamentals/encryption-overview
8. Microsoft. (n.d.). *Azure security logging and auditing*. Microsoft Learn. https://learn.microsoft.com/en-us/azure/security/fundamentals/log-audit